

De la donnée capteur à la décision opérationnelle

Séquence 7 – Confiance, sécurité et robustesse de la chaîne

École de l'air et de l'espace

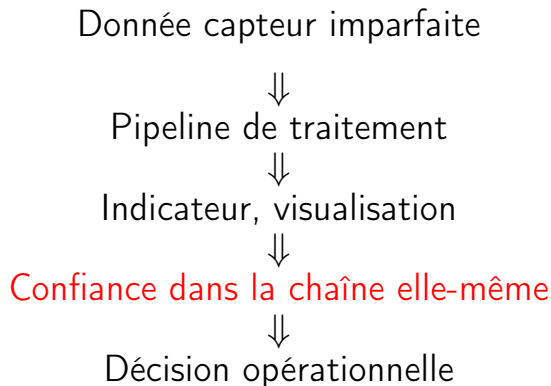
Bienvenue dans la séquence 7

L'idée qui traverse toute la séance

Les séquences précédentes ont supposé que chaque message provenait bien du capteur annoncé, envoyé une seule fois, au moment annoncé. Cette séquence retire cette hypothèse et demande : que vaut un indicateur parfaitement calculé si la chaîne qui l'alimente ne peut pas être qualifiée de confiance ?

- ▶ Le matin, nous distinguons ce qu'une authentification et une liste de contrôle d'accès (ACL) protègent réellement, et ce qu'elles ne protègent pas.
- ▶ L'après-midi, nous analysons un lot dont certains messages sont exactement ce qu'ils prétendent être – et d'autres non – sans qu'aucune valeur ne soit absurde en elle-même.
- ▶ La question n'est jamais « ce message est-il vrai ? », mais « quelle confiance cette chaîne mérite-t-elle, et quelle décision cette confiance permet-elle encore ? »

Le fil rouge des huit séquences



Les séquences 1 à 6 ont construit, nettoyé, résumé et présenté la donnée. Cette séquence questionne une étape antérieure à toutes les autres : la chaîne qui transporte cette donnée mérite-t-elle d'être crue ?

Ce que vous saurez faire à la fin de cette séquence

1. définir intégrité, authentification, ACL, injection et rejeu, et relier chacun à un effet décisionnel précis ;
2. comparer un broker ouvert et un broker protégé sur des cas concrets d'accès autorisé et refusé ;
3. identifier les vulnérabilités d'une chaîne MQTT à partir d'une configuration donnée ;
4. analyser un lot suspect pour y détecter doublons, rejeux et ruptures, sans aucun nouveau calcul ;
5. classer des hypothèses concurrentes par probabilité et impact, et recommander si l'on peut agir sur ces données.

La question qui guidera la séance

Question décisionnelle

Que vaut une décision opérationnelle si l'on ne peut pas qualifier la confiance dans la chaîne de données ?

- ▶ Il ne s'agit pas de prouver qu'une chaîne est parfaitement sûre – aucune ne l'est – mais de savoir nommer précisément ce qu'elle protège et ce qu'elle ne protège pas.
- ▶ Un message peut être numériquement plausible et pourtant ne pas mériter d'être suivi.
- ▶ Le raisonnement attendu distingue la confiance dans la source de la confiance dans le traitement qui la reçoit.

Section 1

Un flux qui ne se comporte pas normalement

Avant tout concept, un simple constat : quelque chose dans ce lot ne va pas.

Le scénario : des messages incohérents

Un extrait de 'comms-shelter-01' contient un message dont l'horodatage de mesure est postérieur à sa réception, et un autre qui semble revenir sur une mesure déjà vue vingt-neuf minutes plus tôt.

Contrainte de décision

Aucune de ces deux anomalies ne porte sur la valeur physique elle-même : la température reste dans une plage parfaitement normale.

La première question n'est donc pas « la mesure est-elle plausible ? » mais « ce message est-il bien ce qu'il prétend être ? »

Avant tout outil : votre décision

Sur la seule base de ce constat, choisissez :

- A. traiter le lot normalement, rien ne semble alarmant en valeur ;
- B. isoler le lot avant toute analyse plus poussée ;
- C. traiter les zones non concernées, isoler 'comms-shelter-01' ;
- D. demander une vérification terrain avant tout traitement.

Notez également :

- ▶ votre confiance de 0 à 100 % ;
- ▶ ce qui, dans un message MQTT, pourrait ne pas être fiable ;
- ▶ ce que la seule valeur mesurée ne peut jamais garantir.

Section 2

Intégrité, authentification, ACL, injection, rejeu

Cinq notions, puis une démonstration : le même broker, avec et sans protection.

Intégrité

Définition

La garantie qu'un message reçu est identique à celui qui a été émis, sans altération en chemin.

- ▶ **Piège fréquent** : confondre intégrité et exactitude – un message intègre peut transporter une mesure fausse dès l'origine.
- ▶ **Effet sur la décision** : sans garantie d'intégrité, un message correctement reçu n'est pas nécessairement le message réellement envoyé par le capteur.

Authentification

Définition

La vérification de l'identité d'un client avant de le laisser se connecter au broker.

- ▶ **Piège fréquent** : croire qu'un broker accessible uniquement en local (127.0.0.1) n'a pas besoin d'authentification.
- ▶ **Effet sur la décision** : sans authentification, n'importe quel client capable d'atteindre le port peut publier un message qui semble provenir d'un capteur légitime.

Liste de contrôle d'accès (ACL)

Définition

Un ensemble de permissions précises, par utilisateur et par topic, appliquées après l'authentification.

- ▶ **Piège fréquent** : croire que l'authentification seule suffit – un utilisateur authentifié mais non restreint peut publier ou lire n'importe quel topic.
- ▶ **Effet sur la décision** : une ACL bien conçue limite un compte capteur compromis à son seul périmètre ; son absence transforme tout compte en accès total.

Injection

Définition

L'introduction dans le flux d'un message qui n'a jamais été produit par un capteur légitime.

- ▶ **Piège fréquent** : supposer qu'un message injecté sera forcément une valeur absurde, donc facile à repérer.
- ▶ **Effet sur la décision** : un message injecté avec une valeur plausible peut influencer une décision exactement comme un message authentique.

Rejeu (replay)

Définition

La republication d'un message déjà vu, sous une identité de message différente, pour le faire passer pour une nouvelle mesure.

- ▶ **Piège fréquent** : chercher un rejeu uniquement parmi les messages strictement identiques – un rejeu change délibérément l'identifiant ou le topic.
- ▶ **Effet sur la décision** : un rejeu peut faire réapparaître une mesure ancienne, rassurante ou alarmante, à un moment où elle ne reflète plus la situation réelle.

Question décisionnelle

Un contrôle qui vérifie qu'un horodatage n'est pas dans le futur suffit-il à détecter un rejeu ?

Auto-vérification avant la démonstration

Un broker accessible uniquement en local peut-il quand même être attaqué ?

Oui : toute machine ou tout conteneur qui atteint ce port – y compris un processus compromis sur la même machine – peut s'y connecter si aucune authentification n'est exigée.

L'authentification suffit-elle à empêcher un abus de droits ?

Non : un compte authentifié mais sans ACL peut publier ou lire sur n'importe quel topic, y compris ceux d'autres capteurs ou d'autres zones.

Démonstration – broker ouvert vs broker protégé

```
docker compose -f docker/docker-compose.yml up -d --wait mosquitto mosquitto-protected
```

```
# 1. anonyme sur le broker ouvert (1883) : reussit
```

```
mosquitto_pub -h 127.0.0.1 -p 1883 -t airbase/test -m hello
```

```
# 2. anonyme sur le broker protege (1884) : refuse a la connexion
```

```
mosquitto_pub -h 127.0.0.1 -p 1884 -t airbase/test -m hello
```

Avant d'exécuter, prédisiez : la seconde commande échoue-t-elle silencieusement, ou avec un message explicite ?

Ce que révèle la démonstration

Tentative	Résultat	Visible pour l'émetteur ?
anonyme → ouvert (1883)	acceptée	–
anonyme → protégé (1884)	refusée à la connexion	oui, explicitement
capteur-lora publie	acceptée (ACL autorisée)	–
superviseur publie	rejetée par l'ACL	non – silencieux
capteur-lora s'abonne	connecté, rien reçu	non – silencieux

Un mauvais mot de passe ou une connexion anonyme sur un broker protégé échoue bruyamment. Un abus de droits sur un compte pourtant authentifié échoue silencieusement : la commande de superviseur se termine sans erreur, alors que son message n'a jamais été délivré.

Exercice – identifier les vulnérabilités d'une chaîne MQTT

Votre mission

À partir de la configuration observée, listez les vulnérabilités présentes et celles que l'ACL protégée corrige.

1. le broker ouvert de `mosquitto.conf` accepte-t-il des clients anonymes ? Qu'est-ce que cela permet à un tiers non autorisé ?
2. une ACL empêche-t-elle un compte compromis de lire les topics d'une autre zone ?
3. les mots de passe et les messages transitent-ils chiffrés entre le client et le broker dans cette configuration ?
4. un message parfaitement authentifié et autorisé peut-il quand même être un rejeu ?

Livrable

Une liste de vulnérabilités, chacune associée à la protection qui la couvre, la protège partiellement, ou ne la couvre pas du tout dans ce laboratoire.

Débrief – ce que l'ACL protège, ce qu'elle ne protège pas

Couvert par l'authentification et l'ACL

- ▶ connexion anonyme non autorisée ;
- ▶ lecture ou écriture hors du périmètre d'un compte.

Non couvert dans ce laboratoire

- ▶ absence de chiffrement (TLS) entre client et broker ;
- ▶ rejeu d'un message par un compte pourtant autorisé à publier ;
- ▶ compromission du compte lui-même (mot de passe volé).

Question décisionnelle

Une chaîne protégée par authentification et ACL est-elle une chaîne digne de confiance ?

Section 3

Confiance dans la source, confiance dans le traitement

Deux confiances distinctes, à qualifier séparément avant toute décision.

Confiance dans la source

Définition

Le degré de certitude que ce message provient bien du capteur, de la zone et de l'instant qu'il annonce.

- ▶ **Piège fréquent** : l'assimiler à la plausibilité de la valeur mesurée – une source usurpée peut transmettre une valeur parfaitement crédible.
- ▶ **Effet sur la décision** : une source non qualifiée fragilise toute décision, même appuyée sur des indicateurs impeccablement calculés.

Confiance dans le traitement

Définition

Le degré de certitude que la pipeline qui reçoit un message ne l'altère pas et ne masque pas ses anomalies.

- ▶ **Piège fréquent** : croire qu'un contrôle qualité (séquence 4) couvre automatiquement les anomalies de sécurité – un rejeu passe les contrôles de champs, d'unité et de plage sans aucune difficulté.
- ▶ **Effet sur la décision** : un traitement qui ne croise jamais l'identité des messages entre eux ne peut détecter un rejeu, quelle que soit la qualité de ses contrôles ligne à ligne.

Question décisionnelle

Un message peut-il franchir tous les contrôles de qualité de la séquence 4 et rester un rejeu ?

Démonstration – diagnostiquer un lot suspect

```
python3 -m iot_decision.chain_trust_cli data/samples/batch004_suspect_scenario.jsonl
```

Ce module ne recalcule rien : il relit les signaux déjà détectables par les modules des séquences 3 et 4 (candidat de rejeu, doublon exact, incohérence temporelle, silence), et les relie à des hypothèses concurrentes.

Activité – Analyse d'un lot suspect

Votre mission

Exécuter le diagnostic sur `batch004_suspect_scenario.jsonl` et interpréter chaque signal.

1. relever le nombre de doublons exacts, de candidats de rejeu, d'incohérences temporelles et la durée du silence non expliqué ;
2. pour chaque signal, identifier la ou les lignes brutes concernées dans le fichier JSONL ;
3. vérifier que la mesure du candidat de rejeu passait bien tous les contrôles de qualité de la séquence 4 ;
4. noter si un seul de ces signaux, pris isolément, aurait suffi à alerter.

Ce que révèle le diagnostic

Signal	Valeur observée
Doublons exacts	1
Candidats de rejeu (même mesure, identité différente)	1
Incohérences temporelles	1
Silence non expliqué (maximum)	15 min

Le candidat de rejeu réutilise la mesure de `comms-shelter-01` de 09 :40 (29,3 °C), republiée sous un nouvel identifiant trente minutes plus tard. Cette mesure est parfaitement valide au sens de la séquence 4 : aucun champ manquant, aucune unité incohérente, aucun horodatage postérieur à la réception.

Section 4

Décider malgré l'incertitude sur la chaîne

Quatre hypothèses concurrentes, une seule question : peut-on agir sur ces données ?

Matrice des risques data/cyber

Hypothèse	Probabilité	Impact	Justification
Suspicion data/cyber	forte	élevé	candidat de rejeu + incohérence temporelle
Problème réseau	forte	moyen	silence non expliqué de 15 min
Panne capteur	moyenne	moyen	1 retransmission exacte détectée
Incident réel	faible	élevé	aucun franchissement de seuil observé

Plusieurs hypothèses restent probables simultanément : elles ne s'excluent pas, elles orientent des vérifications différentes.

Décision – peut-on agir sur ces données ?

Question décisionnelle

Que vaut une décision opérationnelle si l'on ne peut pas qualifier la confiance dans la chaîne de données ?

Recommandation sur ce lot

Ne pas agir directement sur ces données : isoler le lot, vérifier l'identité et la source des messages suspects avant toute décision opérationnelle.

Cette recommandation ne rejette pas le lot : elle en retarde l'usage jusqu'à vérification, exactement comme une confiance faible retardait une conclusion dans les séquences précédentes.

Recommandations de sécurisation minimale

1. désactiver l'accès anonyme dès qu'un broker dépasse le cadre d'un laboratoire strictement local ;
2. attribuer une ACL par rôle, jamais un compte unique partagé entre tous les capteurs ;
3. conserver l'identifiant de message et le topic d'origine pour pouvoir croiser les messages entre eux, pas seulement les valider un par un ;
4. ne jamais déduire qu'un message est sûr du seul fait qu'il a franchi les contrôles de qualité de la séquence 4.

Question décisionnelle

Laquelle de ces quatre recommandations aurait, seule, empêché le candidat de jeu de ce lot ?

Restitution – 150 mots maximum

Rédigez une recommandation contenant :

1. la ou les hypothèses retenues, avec probabilité et impact ;
2. un niveau de confiance dans la chaîne, distinct de la confiance dans les valeurs mesurées ;
3. deux preuves chiffrées et retrouvables, avec leur fichier source ;
4. une vérification prioritaire avant toute décision opérationnelle.

Transition vers la suite du cours

Le mini-projet final s'appuiera directement sur cette séquence :

1. un lot ambigu peut combiner un problème de qualité (séquence 4), un indicateur trompeur (séquence 5) et un signal de confiance dans la chaîne (séquence 7) ;
2. aucune de ces trois familles de vérification n'en remplace une autre.

Retenez ce réflexe : un message qui franchit tous les contrôles de qualité n'a pas nécessairement franchi un contrôle de confiance dans la chaîne – ce sont deux vérifications différentes.

Activité – Synthèse individuelle

Complétez les trois phrases, seul et sans écran :

1. Un message peut être valide au sens de la séquence 4 et pourtant ...
2. L'authentification protège contre ... ; l'ACL protège en plus contre ...
3. Avant d'agir sur un lot dont la chaîne n'est pas qualifiée, je vérifierais ...

Message incohérent → signaux de confiance → hypothèses concurrentes → isolement et vérification → décision différée, pas refusée.

Ce que la séance a permis d'établir – synthèse de référence

Résultat de référence sur ce lot

Un doublon exact, un candidat de rejeu et une incohérence temporelle sur `comms-shelter-01`, plus un silence non expliqué de 15 minutes, placent « suspicion data/cyber » en tête des hypothèses (probabilité forte, impact élevé), devant un problème réseau plausible mais secondaire.

Une recommandation défendable, à titre d'exemple

Isoler le lot, vérifier l'identité et la source des messages suspects avant toute décision opérationnelle ; ne jamais confondre la validité ligne à ligne d'un message avec la confiance dans son identité.

D'autres formulations restent recevables si elles distinguent explicitement confiance dans la source, confiance dans le traitement, et qualité au sens de la séquence 4.

Références et ressources

- ▶ Eclipse Mosquitto, documentation `mosquitto.conf` (authentication, password_file, acl_file) : <https://mosquitto.org/man/mosquitto-conf-5.html>
- ▶ OASIS, *MQTT Version 5.0 Specification*, section sur les messages retained et la persistance : <https://docs.oasis-open.org/mqtt/mqtt/v5.0/mqtt-v5.0.html>
- ▶ NIST IR 8259A, *IoT Device Cybersecurity Capability Core Baseline*, 2020 : <https://doi.org/10.6028/NIST.IR.8259A>
- ▶ OWASP, *OWASP Internet of Things Top 10* : <https://owasp.org/www-project-internet-of-things/>
- ▶ ANSSI, recommandations de sécurité relatives aux objets connectés : <https://www.ssi.gouv.fr/>